

Security Threat Identification

Penetration Testing Report

Cyber Security — Batch 9.145 (29 June)

1. Environment Setup

- Virtualization platform: Oracle VirtualBox
- Target VM: Metasploitable2 — IP 192.168.56.102 (Host-only network)
- Attacker machine: Kali Linux 2026.1 — IP 192.168.56.101 (Host-only network)
- Tools used: Nmap 7.98, Wireshark, Nessus Essentials (Basic Network Scan policy)

2. Reconnaissance Summary

Target IP was confirmed on the Metasploitable2 VM via ifconfig, then scanned from Kali using an aggressive service, version, and OS-detection Nmap scan:

```
sudo nmap -sS -sV -O 192.168.56.102
```

The scan completed in 23.57 seconds and returned 23 open TCP ports. Full results:

Port	Service	State	Version / Notes
21/tcp	ftp	open	vsftpd 2.3.4 — known backdoor (CVE-2011-2523)
22/tcp	ssh	open	OpenSSH 4.7p1 Debian 8ubuntu1
23/tcp	telnet	open	Linux telnetd — unencrypted
25/tcp	smtp	open	Postfix smtpd
53/tcp	domain	open	ISC BIND 9.4.2
80/tcp	http	open	Apache httpd 2.2.8 (Ubuntu) DAV/2
111/tcp	rpcbind	open	RPC #100000
139/445	netbios-ssn	open	Samba smbd 3.X–4.X (WORKGROUP)
512-514	exec/login/shell	open	Legacy r-services — unencrypted
1099/tcp	java-rmi	open	GNU Classpath grmiregistry
1524/tcp	bindshell	open	Metasploitable root shell — unauthenticated
2049/tcp	nfs	open	RPC #100003
2121/tcp	ftp	open	ProFTPD 1.3.1
3306/tcp	mysql	open	MySQL 5.0.51a-3ubuntu5
5432/tcp	postgresql	open	PostgreSQL DB 8.3.0–8.3.7
5900/tcp	vnc	open	VNC protocol 3.3

Port	Service	State	Version / Notes
6667/tcp	irc	open	UnrealIRCd — known backdoor (CVE-2010-2075)
8009/tcp	ajp13	open	Apache Jserv Protocol v1.3
8180/tcp	http	open	Apache Tomcat/Coyote JSP engine 1.1

OS fingerprinting returned no exact match, likely due to Metasploitable2's intentionally minimal and non-standard network stack rather than the Host-only network setup itself; service banners (vsftpd, OpenSSH, Apache) confirm a Linux host consistent with Metasploitable2's known Ubuntu 8.04 base.

3. Network Traffic Analysis

Traffic was captured with Wireshark on the eth0 interface while interacting with the target's FTP and HTTP services.

FTP Capture (filter: ftp)

- Packet 64 — Request: USER gopika
- Packet 68 — Request: PASS gopika
- Packet 72 — Response: 530 Login incorrect

Both the username and password were transmitted and visible in fully readable plaintext, confirming FTP does not encrypt session data. This matches the vsftpd 2.3.4 finding from the port scan.

HTTP Capture (filter: http)

- Packet 30 — Request: GET / HTTP/1.1, Host: 192.168.56.102
- Packet 32 — Response: HTTP/1.1 200 OK (text/html)

The full HTTP request, including headers, was visible in cleartext in the packet bytes — consistent with the target running plain HTTP (no TLS) on port 80.

4. Vulnerability Scan (Nessus)

Scan policy	Basic Network Scan
Target	192.168.56.102
Authentication	Failed / Unauthenticated (external black-box scan)
Duration	19 minutes
Total findings	70 (10 Critical, remainder High / Medium / Low / Info)

Key Critical and High severity findings:

Severity	CVSS	Finding
Critical	9.8	Bind Shell Backdoor Detection — unauthenticated root shell on port 1524
Critical	9.8	SSLv2/SSLv3 Protocol Detection — obsolete encryption, vulnerable to POODLE-class attacks

Severity	CVSS	Finding
Critical	10.0	Canonical Ubuntu Linux SEoL (8.04.x) — OS is end-of-life; no security patches available
Critical	10.0	VNC Server 'password' Password — default/trivial credential in use
High	7.5	NFS Shares World Readable — file shares accessible without authentication
High	7.5	rlogin Service Detection — legacy remote login, unencrypted
High	7.5	Samba Badlock Vulnerability (CVE-2016-2118) — allows interception/manipulation of SMB traffic

Additional grouped findings included multiple Apache Tomcat issues, SSL/TLS certificate and cipher weaknesses, and multiple ISC BIND (DNS) issues — these are lower-severity and summarized here rather than itemized individually.

5. Threat Summary & Impact

Threat	Description	Potential Impact	Mitigation
FTP Backdoor	vsftpd 2.3.4 contains a known backdoor allowing remote root shell access	Full remote code execution	Disable or upgrade FTP service to a patched version
Unauthenticated Bind Shell	Port 1524 exposes a root shell with no login required	Immediate full system compromise	Close port 1524; audit for backdoor processes
Plaintext Credentials	FTP and Telnet transmit login credentials with no encryption (confirmed via Wireshark)	Credential theft, session hijacking	Disable Telnet; use SFTP/FTPS instead of plain FTP
Weak VNC Credential	VNC service uses the password "password"	Full graphical remote-desktop takeover	Enforce strong, unique passwords for all remote-access services
End-of-Life Operating System	Underlying Ubuntu 8.04.x base has reached Security End-of-Life	No vendor patches available for any future vulnerability	Upgrade to a currently supported OS version
UnrealIRCd Backdoor	IRC daemon on port 6667 (CVE-2010-2075) contains a trojanized backdoor allowing arbitrary remote command execution without authentication	Remote code execution with the privileges of the IRC service, full host compromise possible	Remove the trojanized package; reinstall IRC daemon from a verified source or disable the service

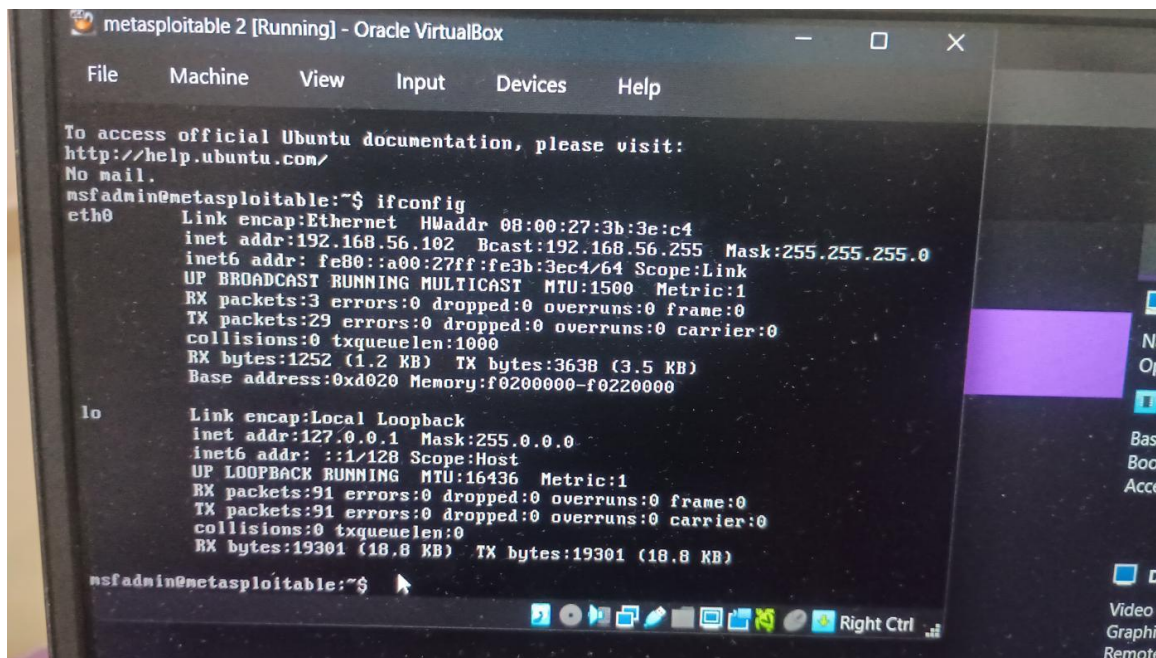
6. Conclusion

This assessment identified a critical-risk target environment consistent with an intentionally vulnerable training system. The most severe findings were an unauthenticated root-level bind shell on port 1524, the well-documented vsftpd 2.3.4 backdoor, and an end-of-life operating system with no available patches. Live packet capture confirmed that FTP and HTTP traffic — including login credentials — are transmitted in plaintext and can be trivially

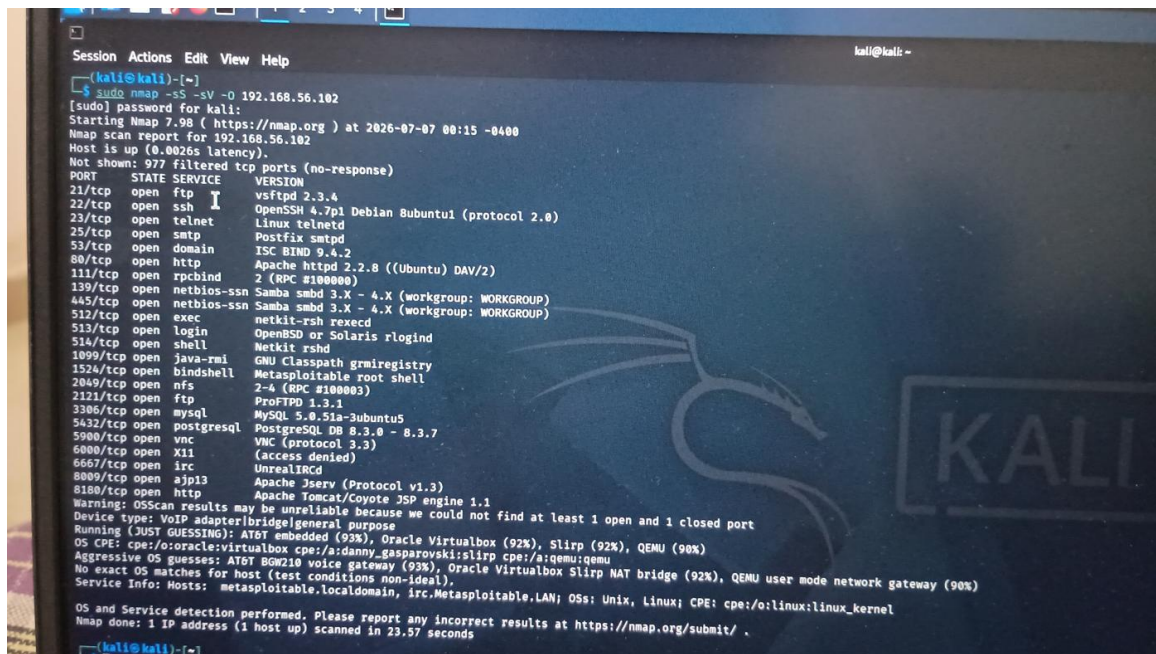
intercepted. Immediate remediation priorities are: closing or firewalling the bind-shell port, patching or removing the vulnerable FTP service, replacing all plaintext remote-access protocols (Telnet, FTP, rlogin) with encrypted equivalents (SSH, SFTP), enforcing strong credentials on all remote services, and planning an OS upgrade path away from the end-of-life base image.

Appendix: Evidence Screenshots

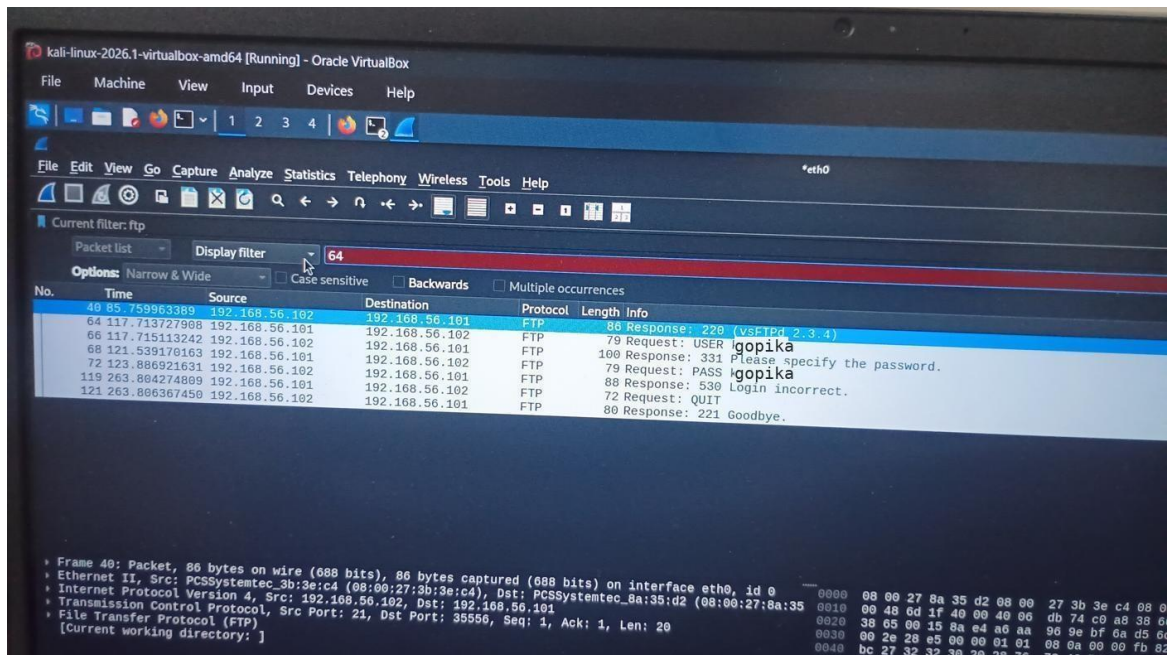
A1. Target IP Confirmation (ifconfig on Metasploitable2)



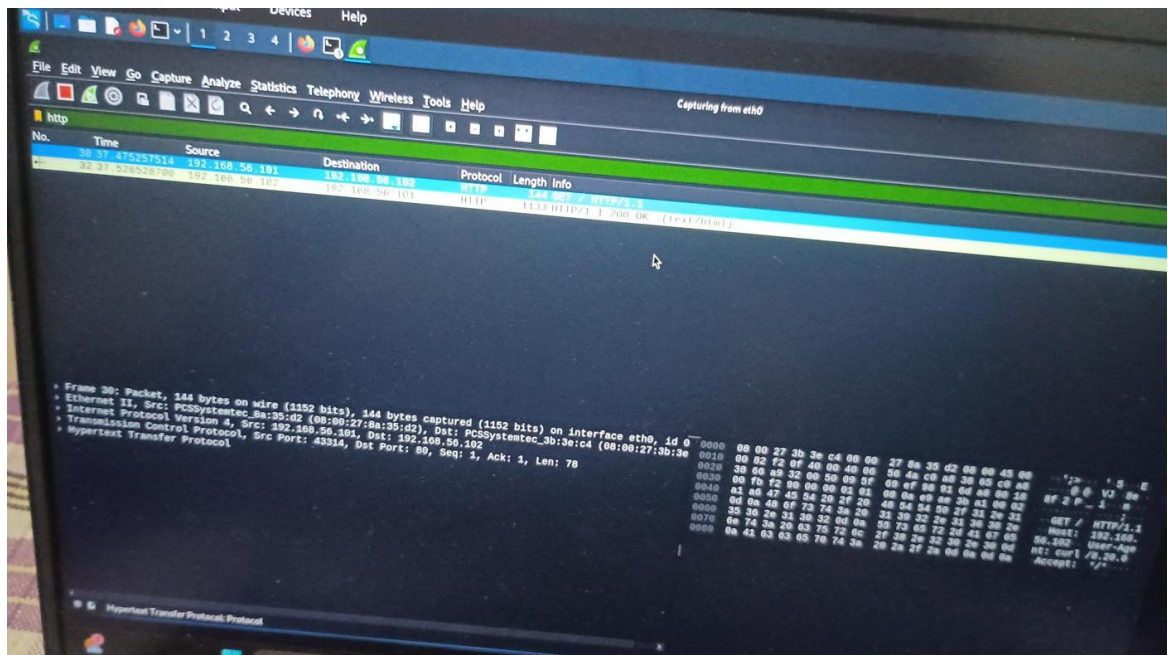
A2. Nmap Service/Version/OS Scan



A3. Wireshark — FTP Credentials Captured in Plaintext



A4. Wireshark — HTTP Request/Response Captured



A5. Nessus — Critical & High Severity Findings

meta2scan

Back to All Scans

Configure

Audit Trail

Hosts 1

Vulnerabilities 78

Remediations 1

Notes 4

History 1

Filter

Search Vulnerabilities

70 Vulnerabilities

Sev	CVSS	VPR	EPSS	Name	Family	Count	
MIXED	...	...	...	Apache Tomcat (Multiple Issues)	Web Servers	4	
CRITICAL	...	...	...	SSL (Multiple Issues)	Gain a shell remotely	3	
CRITICAL	9.8			SSL Version 2 and 3 Protocol Detection	Service detection	2	
CRITICAL	9.8			Bind Shell Backdoor Detection	Backdoors	1	
CRITICAL	10.0			Canonical Ubuntu Linux SEOL (8.04.x)	General	1	
CRITICAL	10.0 *			VNC Server 'password' Password	Gain a shell remotely	1	
MIXED	...	...	...	SSL (Multiple Issues)	General	28	
MIXED	...	...	...	ISC Bind (Multiple Issues)	DNS	3	
CRITICAL	7.5			NFS Shares World Readable	RPC	1	
CRITICAL	7.5 *			rlogin Service Detection	Service detection	1	
CRITICAL	7.5			Samba Badlock Vulnerability	General	1	

Scan Details

Policy:

Status:

Severity Base:

Scanner:

Start:

End:

Elapsed:

Vulnerabilities

Search

ENG IN